

User Study Analysis Report: System Evaluated “SecureMail”

Focus on Task 3: Phishing Mitigation through Nudging

Lopetuso Alessia - Caterina Francesco

Department of Computer Science

University of Bari Aldo Moro

Usable Privacy and Security

Prof. Giuseppe Desolda

Abstract

This study analyzes the effectiveness of nudging and visual friction in preventing phishing attacks, with the aim of addressing vulnerabilities related to users' cognitive fatigue. The experiment, focused on Task 3, evaluated the impact of a highly salient red security banner compared with a standard gray warning. The methodology consisted of an A/B test with a within-subjects design on a sample of 12 non-expert participants, supported by a rigorous counterbalancing protocol. The results confirm the effectiveness of the mitigation strategy; however, they also reveal a marked trade-off between security and usability, since the increase in protection generated greater frustration, longer completion times, and a decrease in perceived usability (SUS) below the acceptability threshold.

User Study Analysis Report: System Evaluated “SecureMail”

Focus on Task 3: Phishing Mitigation through Nudging

Introduction

Context and the Cognitive Problem

At present, recent and restrictive directives such as NIS2 require users and organizations to adopt security, protection, and corporate policy measures. Among these measures, frequent password changes are one of the standard practices adopted by most companies. Failing to regularly update access credentials makes accounts vulnerable to various types of attacks and, according to recent reports, still accounts for as much as 30% of cyberattacks (IBM X-Force, 2025). However, in practice these requirements often prove ineffective. When people are asked to comply with strict rules, they are affected by human limitations such as cognitive fatigue and bias; this imposes a much higher cognitive load on users and creates vulnerabilities. To overcome the obstacle, users adopt small shortcuts, such as adding a number to the end of the previous password to make it appear more secure, but this is only a superficial solution because many data breaches still derive from human error.

The Paradigm Shift: Nudging

To overcome this vulnerability, a paradigm shift is necessary: it is not enough to instruct users to “pay more attention”; interfaces must evolve so that threat identification becomes a natural visual process. This approach is based on the principles of nudging. These principles start from the assumption that human beings rarely make decisions in a fully rational way, since they are often influenced by biases, fatigue, or distractions. Through an appropriate “choice architecture,” the interface can be structured to proactively guide users toward better and safer decisions, interrupting dangerous automatisms without prohibiting any navigation option.

Study Objective and Hypothesis

The idea is that, in order to solve this problem, it is necessary to change the way of thinking by creating interfaces that evolve and make the interaction process more

natural. This takes place through the principles of nudging, which are based on the idea that human beings almost never make decisions rationally, but are instead influenced by various biases, fatigue, habits, or distractions. In this specific project, an architecture is created that guides the user toward better decisions without prohibiting any option. Considering the results obtained from the previous study, based on the “SecureMail” design, we focused on Task 3 and therefore tested the following hypothesis:

H1: *“The implementation of a red warning banner indicating the external origin of the email will reduce the task failure rate compared with the original design.”*

Methodology

Participants

For this study, a sample of 12 people was recruited (7 men and 5 women). Most participants were between 18 and 25 years old (5 men and 2 women), one participant was between 26 and 35 years old (1 woman), and the remaining participants were between 46 and 56 years old (2 men and 2 women). Almost all participants had a high school diploma (6 men and 4 women); among them, some were university students in fields such as “Education Sciences” (1 woman), “Pharmacy” (1 woman), and “Agriculture” (1 man). The remaining participants had only a middle school diploma (1 man and 1 woman). None of them held a university degree. Participants who were not students worked in fields unrelated to technology: waiter (2 men), police officer (1 man), kindergarten teacher (1 woman), healthcare assistant (1 woman), and self-employed workers (1 man and 1 woman). Only one participant was unemployed, but had a diploma from a hospitality school and therefore had no specific technological expertise. Specifically, 8 participants (5 men and 3 women) stated that they use digital devices only for online shopping or social media, 3 participants (1 man and 2 women) use them for studying, and only 1 participant (1 man) reported using electronic devices rarely because he was not very familiar with them. None of the participants had specific IT or cybersecurity skills; furthermore, none held basic IT certifications such as ECDL.

Design

Since it was not possible to recruit a sufficient number of people, we opted for a *within-subjects* design. To control for the order effect, a counterbalancing protocol with sealed envelopes was used: 12 identical envelopes were prepared, 6 containing a note with the sequence “A then B” and 6 with “B then A.” Upon arrival, each participant randomly selected an envelope that determined the testing order of the two prototypes. A break of approximately 3 minutes was inserted between the first and second session to reduce fatigue. The independent variable was the interface design condition, with two levels:

- **Condition A (Original):** the original SecureMail prototype, in which the phishing email (Task 3) displayed a gray warning banner, stylistically similar to the rest of the interface and easily ignored.
- **Condition B (Mitigated):** the modified prototype, in which the same email displayed a bright red warning banner with a danger icon, critical warning text, and no quick close button.

The dependent variables collected for Task 3 were:

- **Failure Rate**
- **Task Completion Time (TCT)**
- **NASA-TLX Scores**
- **SUS Score**

Materials

The prototype used for this test was SecureMail, a simulated email inbox environment including a login section, inbox, and settings. In particular, we focused on Task 3, which in the previous exercise had produced the highest failure rate. In the original prototype, users were deceived when, while looking for the email needed to complete the task (IT HelpDesk – phishing email), they failed to notice the danger that the system was trying to show them because they ignored the gray banner, which could easily be closed and therefore seemed like a simple notification.

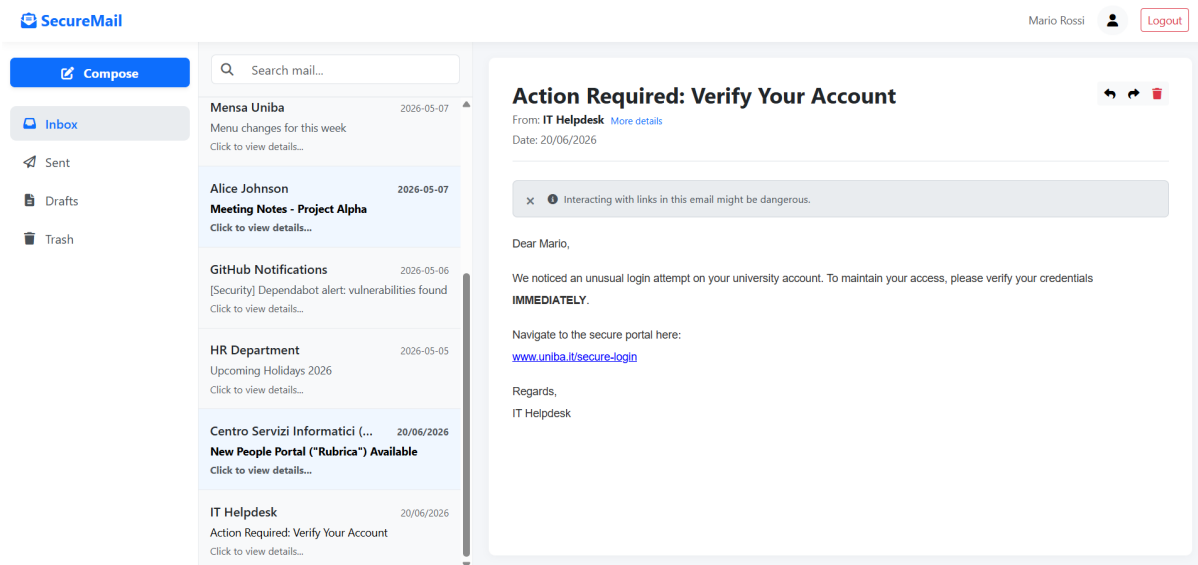


Figure 1

Original prototype of Task 3.

We therefore reasoned that this gray banner did not provide any visual alarm signal, causing most users to ignore the warning and click the malicious link. For this reason, we redesigned the original prototype in order to steer users toward appropriate behaviors that would keep them safe. The design of the mitigated prototype is based on changing a single element: the gray banner was replaced with a bright red banner characterized by:

- A prominent *triangle-exclamation* icon;
- Warning text: “CRITICAL SECURITY WARNING: This email originates from a

suspicious external source. The links below may be malicious (Phishing). Do not click.”;

- No close button, forcing the user to process the warning content.

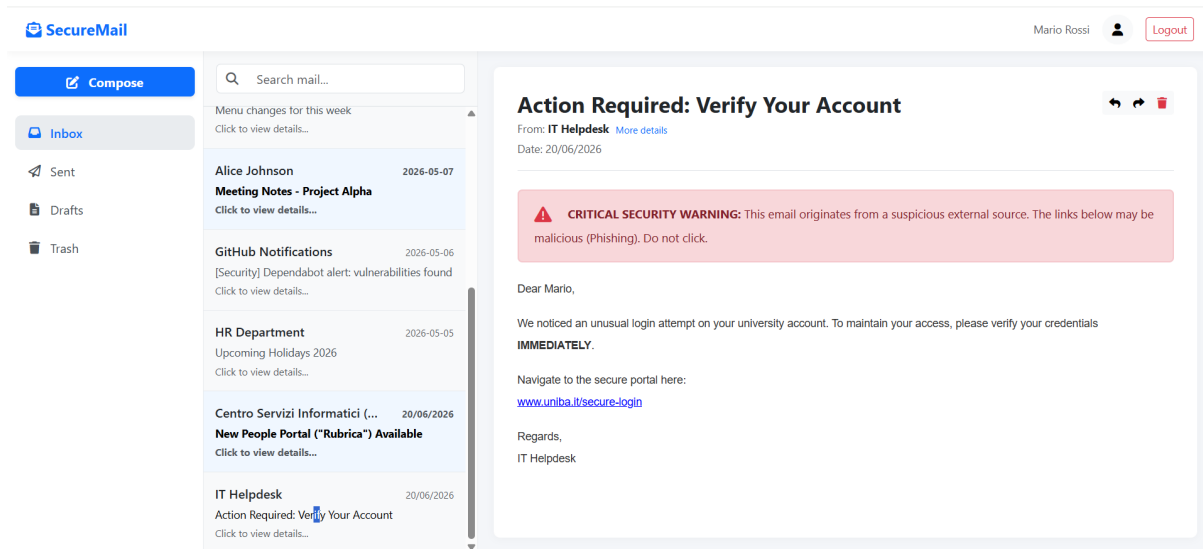


Figure 2

Mitigated prototype of Task 3.

This approach is based on the principle of *visual friction*: introducing an element of visual friction that interrupts the user's automatic behavior and forces them to process the content.

Procedure

The test was conducted in a controlled environment in which both an observer and a facilitator were present. The observer was responsible for monitoring user behavior and taking notes, while the facilitator managed the test by asking participants to complete specific tasks and fill out the questionnaires. Before starting the test, each user was asked to read and sign a consent form for data processing and for permission to record the screen and audio. The test initially involved, after starting the screen and audio recording, a brief description of the usage scenario, followed by asking the user to perform each task on the assigned prototype. The true purpose of the test was not disclosed to the user, so that the participant would not be influenced in any way. After presenting the use case, the user was asked to complete the first task on the randomly assigned prototype. After completing it, the user was asked to fill out the NASA-TLX questionnaire. Once Task 1 was completed, the test moved on to the second task, and after completing that task another NASA-TLX questionnaire was administered. This procedure was the same for all four tasks. After completing the tasks on the first prototype, the user was asked to complete the SUS questionnaire. After that, the user had a break of approximately 3 minutes before moving on to the second randomly assigned prototype. The procedure was the same as for the previous prototype. At the end of the task completion and questionnaire phase, the true purpose of the test was revealed to the user, and then they were asked a few questions about their behavior throughout the test.

Data Exclusion Log

During the data cleaning phase, no measurement or test session was excluded. All recorded interactions were valid and complete in every respect.

Results

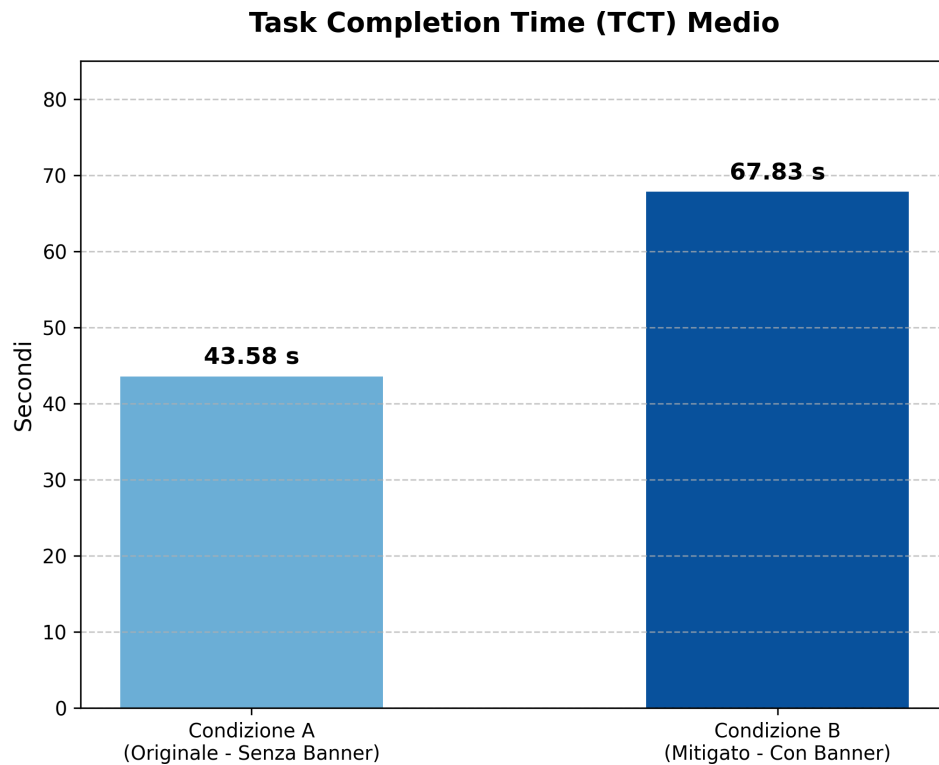
The descriptive analysis of behavioral outcomes (Table 1) reveals a substantial difference between the two design conditions. Using the original prototype (Condition A), the baseline failure rate for the 12 participants was critical, reaching 83.3% (10 users out of 12 fell victim to phishing). By contrast, the interaction of the same participants with the mitigated design (Condition B), characterized by the highly visually salient red banner, led to a drop in the failure rate to 16.7%. In addition, impulsive behaviors (actions performed in less than 3 seconds) also decreased from 50.0% in Condition A to 33.3% in Condition B.

However, this drastic improvement in security introduced considerable friction into the user experience. On average, participants took much longer to complete the task in Condition B ($M = 67.83$ seconds, $SD = 11.28$) than in Condition A ($M = 43.58$ seconds, $SD = 6.24$). Even more relevant is the visible frustration recorded by the observers: while in the original design only 8.3% of users showed signs of frustration, in the alternative design 58.3% of the sample (7 users out of 12) showed signs of stress or dissatisfaction when faced with the visual warning.

Table 1

Behavioral metrics collected through the Observation Matrix during Task 3.

Prototype	Users	Failure Rate	Impulsiveness	Mean TCT (s)	Frustration
Original (A – Without Banner)	12	83.3%	50.0%	43.58	8.3%
Alternative (B – With Banner)	12	16.7%	33.3%	67.83	58.3%

**Figure 3**

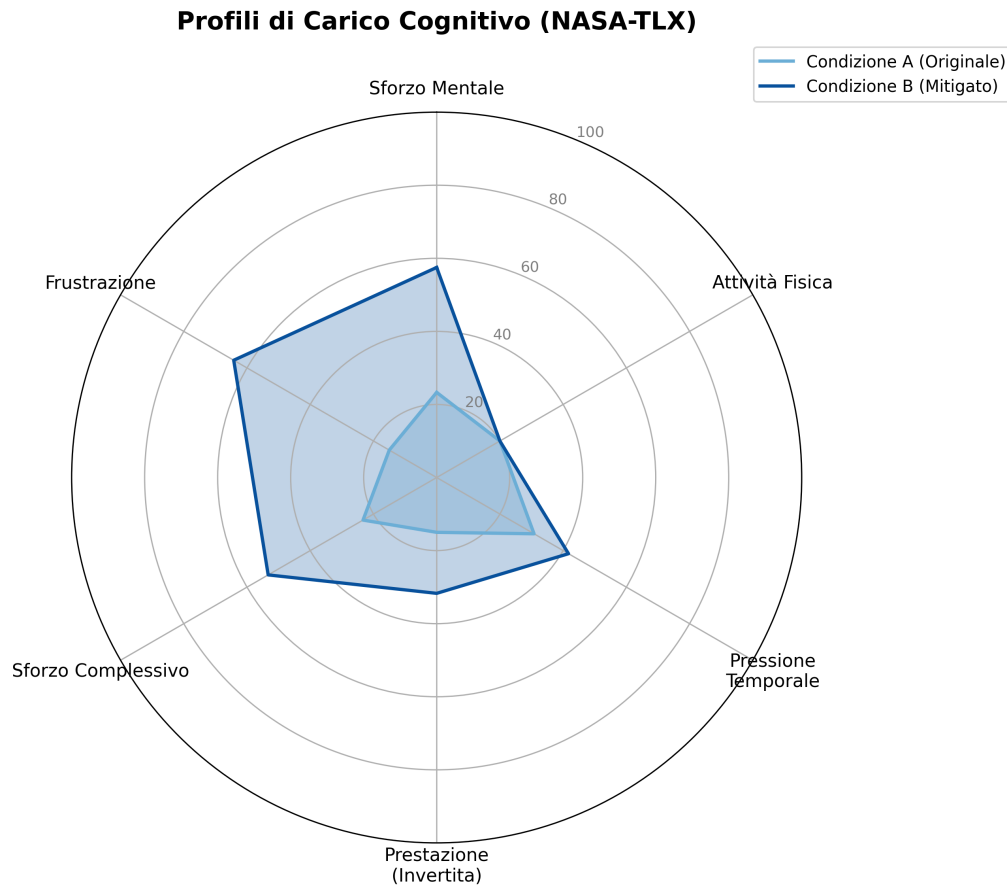
Comparison of mean Task Completion Time (TCT).

A first descriptive analysis of the data collected through the NASA-TLX questionnaire (Table 2) highlights a general increase in cognitive workload when using the alternative prototype. In particular, the levels of mental demand, overall effort, and frustration are markedly higher in Condition B than in Condition A.

Table 2

Mean NASA-TLX scores for Task 3.

Prototype	Mental	Physical	Temporal	Performance	Effort	Frustration	Mean
Original (A – Without)	23.3	20.0	30.8	15.0	23.3	15.0	21.25
Alternative (B – With)	57.5	20.0	41.7	31.7	53.3	64.2	44.72

**Figure 4**

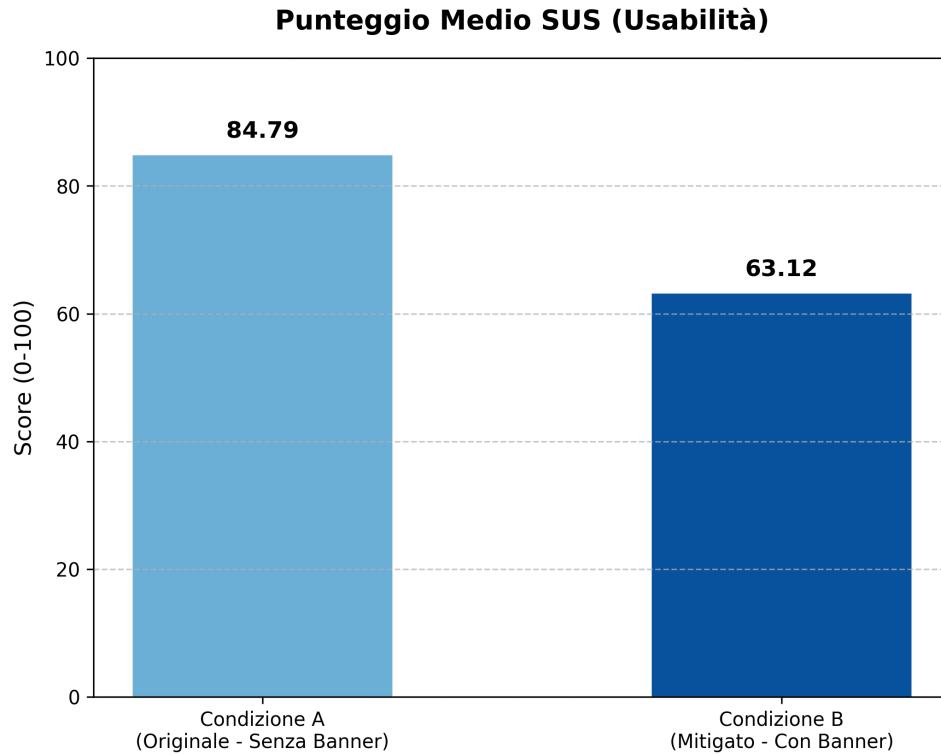
Comparison of cognitive workload profiles (NASA-TLX).

As shown in Table 3, perceived usability (SUS) decreased. The original prototype (Condition A) recorded an excellent mean score ($M = 84.79$, $SD = 4.75$), whereas the introduction of the red banner (Condition B) lowered the score to 63.12 ($SD = 9.18$), a value slightly below the standard acceptability threshold (68).

Table 3

Mean System Usability Scale (SUS) scores for the two test conditions.

Interface Condition	Mean SUS Score
Original (A – Without Banner)	84.79
Alternative (B – With Banner)	63.12

**Figure 5**

Mean System Usability Scale (SUS) score.

The behavioral metrics (failure rate, impulsiveness, frustration) indicate the percentage frequencies calculated over the total sample ($n = 12$), while TCT represents the mean execution time in seconds. Regarding the questionnaires, NASA-TLX scores were converted to a 0–100 scale (inverting the “Performance” metric so that a high value always indicates high cognitive workload), while the SUS score was obtained by applying the standard international formula that normalizes the score on a scale from 0 to 100. The data reveal a clear trade-off between security and usability. The nudging introduced by the red banner (Condition B) was highly effective for security, reducing the failure rate from 83.3% to 16.7% and decreasing users’ impulsiveness. However, this visual friction strongly penalized the experience: completion time increased by approximately 24 seconds and the majority of the sample (58.3%) showed visible signs of frustration. The questionnaires confirm this discomfort: cognitive workload (NASA-TLX) was markedly higher and perceived usability (SUS) dropped from an excellent score (84.79) to an insufficient score (63.12), falling below the standard

acceptability threshold.

Bias Control: Analysis of the Order Effect

To ensure that the positive results of Prototype B were not affected by a learning effect, that is, by users becoming faster and more experienced simply because they had already completed the test once, the counterbalancing protocol divided the sample of 12 participants into two groups. The objective data show that there was no systematic learning bias. The group that started with Prototype B completed the tasks in an overall mean time of 53.8 seconds, a value consistent with and not significantly faster than the group that started with Prototype A (57.6 seconds). Consequently, the variations recorded in TCT and failure rate can be attributed exclusively to the architectural differences in the design and not to familiarity with the system.

Discussion

The experimental data we collected demonstrate that the research hypothesis (H1) is strongly supported. The mitigated prototype (Condition B) produced a failure rate of 16.7%, showing a substantial decrease compared with the original prototype (Condition A), whose failure rate was 83.3%. This reduction in the failure rate shows that the introduction of visual friction, namely the red banner (compared with the previous gray one) combined with the impossibility of closing the banner, led users not to click the warning impulsively but instead encouraged them to focus on what was written and analyze the content. This is also demonstrated by the data regarding the impulsiveness rate: the original prototype (Condition A) showed a rate of 50%, while the mitigated prototype (Condition B) decreased to 33.3%, showing that the nudging strategy was successful. On the other hand, the results also highlight a problem between security and usability: although there was a clear improvement in security, users experienced psychological discomfort and a slowdown. It is evident that completing Task 3 with the mitigated prototype (Condition B) took more time ($M = 67.83$ seconds, $SD = 11.28$) than with the original prototype (Condition A), which had a mean time of ($M = 43.58$ seconds, $SD = 6.24$), resulting in an overall increase of about 24 seconds for task completion. It is also important to highlight that the NASA-TLX scores related to mental demand and frustration were much higher in Condition B, respectively 59.2 and 62.5, compared with Condition A, which showed a mental demand score of 25.8 and a frustration score of 15.8. In fact, these signs of frustration and cognitive fatigue observed in the results, which show that from a security perspective users were much less likely to fall into the trap, are counterbalanced by the system's usability, which was downgraded from excellent, with a score of 84.79, to insufficient, with a score of 63.12. It is clear that these results demonstrate that the mitigated prototype can protect real-world users, making them safer and less vulnerable to cyberattacks such as phishing emails. However, if users were exposed every day to this type of visual friction for every suspicious email they received, they would be under constant stress, leading to the phenomenon of alert fatigue. Users would then perceive security measures as an

annoyance and would tend to look for shortcuts to avoid them. In conclusion, the use of visual friction, despite the resulting frustration, can be considered an excellent solution for single or highly critical threats, such as phishing emails.

Study Limitations

The study we conducted presents some limitations that must be considered when interpreting the results. First, the number of participants in our study was small ($n = 12$), which reduces the generalizability of the experimental results. Although our data show a reduction in the failure rate (from 83.3% to 16.7%), such a small sample cannot be used to generalize the effectiveness of the red banner. Furthermore, the environment in which the experiment was conducted must be considered, in relation to the so-called Hawthorne effect. The experiment was carried out in a controlled environment, under the observation of a facilitator and an observer. In real life, however, people often read emails quickly or while distracted. Knowing that they were being observed may have pushed users to behave differently from usual. For example, the increase in completion time to 67.83 seconds in Condition B may have depended on the fact that participants felt “under examination,” forcing themselves to complete the task at all costs. In a real and unsupervised context, faced with a similar visual obstacle, users would probably have closed the email within a few seconds. Finally, a limitation related to the SUS questionnaire emerges, which can be explained by the so-called *halo effect*. In the mitigated prototype, only one visual element was modified, and it appeared exclusively in Task 3. Although the other tasks (1, 2, and 4) were identical in both conditions, the overall SUS score dropped from 84.79 to 63.12. This result shows how the frustration experienced during a single moment of the experiment led users to evaluate the entire application negatively.

Future Developments

Considering the trade-off obtained, future developments should focus on balance. The goal should be to maintain visual friction while reducing users' frustration load. For example, instead of a red banner, a threat intelligence mechanism could be implemented to further reduce the risk of clicking phishing emails or messages containing malicious payloads. Another possibility would be to modify the banner closing option: the prototype could include a close button with a 3–5 second delay, so that the system can preserve the user's sense of control over the interface.

Conclusions

In conclusion, this study confirms the research hypothesis (H_1). The introduction of *visual friction* proved to be an effective tool for mitigating the risk of *phishing*, reducing the failure rate from 83.3% to 16.7% and successfully interrupting users' automatisms. However, the data reveal a marked *trade-off* between security and usability: the increase in protection was achieved at the cost of severe user frustration and a collapse in system usability. Therefore, although *nudging* represents an excellent countermeasure for blocking critical and isolated threats, future security architectures will need to better balance this visual friction.